
CIRA — Cloud Infrastructure Realtime Analysis

CSPM + FinOps Platform — Spécifications Fonctionnelles et Techniques

Information	Valeur
Version	4.0
Date	Mai 2026
Équipe	6 personnes (10h/sem = 60h/sem)
Durée MVP	20 semaines
Total SP	~202 SP = ~808h

Résumé Exécutif

Ce document constitue la référence technique et fonctionnelle du projet CIRA. Il décrit, fonctionnalité par fonctionnalité, ce que le système doit faire (spécifications fonctionnelles), comment il doit le faire (spécifications techniques), ainsi que les contraintes, dépendances et interfaces associées. Il intègre les arbitrages validés : remédiation “one-click safe” avec approval obligatoire en v1, multi-cloud AWS+Azure en phase 2 (GCP phase 3), Compliance as Code via OPA/Rego, boucle de feedback ML dès la phase 3, frontend server-side rendering Templ + Datastar (sans React ni GraphQL), et sessions cookie via alexedwards/scs + Redis (sans JWT).

Table des Matières

1. Périmètre et Contexte
 2. Architecture Générale
 3. Module 1 — Authentification
 4. Module 2 — Connexion Cloud AWS + Azure
 5. Module 3 — Scanner CSPM (open-source)
 6. Module 4 — Scoring IA LightGBM
 7. Module 5 — Analyse des Coûts
 8. Module 6 — Compliance as Code OPA/Rego
 9. Module 7 — Remédiation One-Click Safe
 10. Module 8 — Dashboard et Reporting
 11. Module 9 — Alertes et Notifications
 12. Module 10 — API Publique
 13. Contraintes Non-Fonctionnelles
 14. Questions Ouvertes
 15. Historique des Versions
-

Documents de Référence

- **Cahier_Des_Charges_CIRA.docx** — Contrat interne : exigences fonctionnelles, critères d'acceptance contractuels et indicateurs de succès. Les critères d'acceptance présents dans ce document sont le niveau technique détaillé, complémentaires au CdC.
 - **Justification_Choix_CIRA.docx** — Justifications détaillées des choix technologiques. Ce document décrit le “quoi” ; le “pourquoi” est dans la Justification des Choix.
 - **RACI_CIRA.docx** — Responsable principal de chaque module (voir section 3.4 du RACI).
 - **Description_Fonctionnelle_CIRA.md** — Vue utilisateur non technique des mêmes fonctionnalités.
-

1. Périmètre et Contexte

1.1 Présentation du Produit

CIRA est une plateforme de Cloud Security Posture Management (CSPM) ciblant les PME européennes. Elle analyse en continu l'infrastructure cloud des clients et retourne trois scores actionnables : sécurité, optimisation des coûts et conformité réglementaire.

1.2 Principes Directeurs

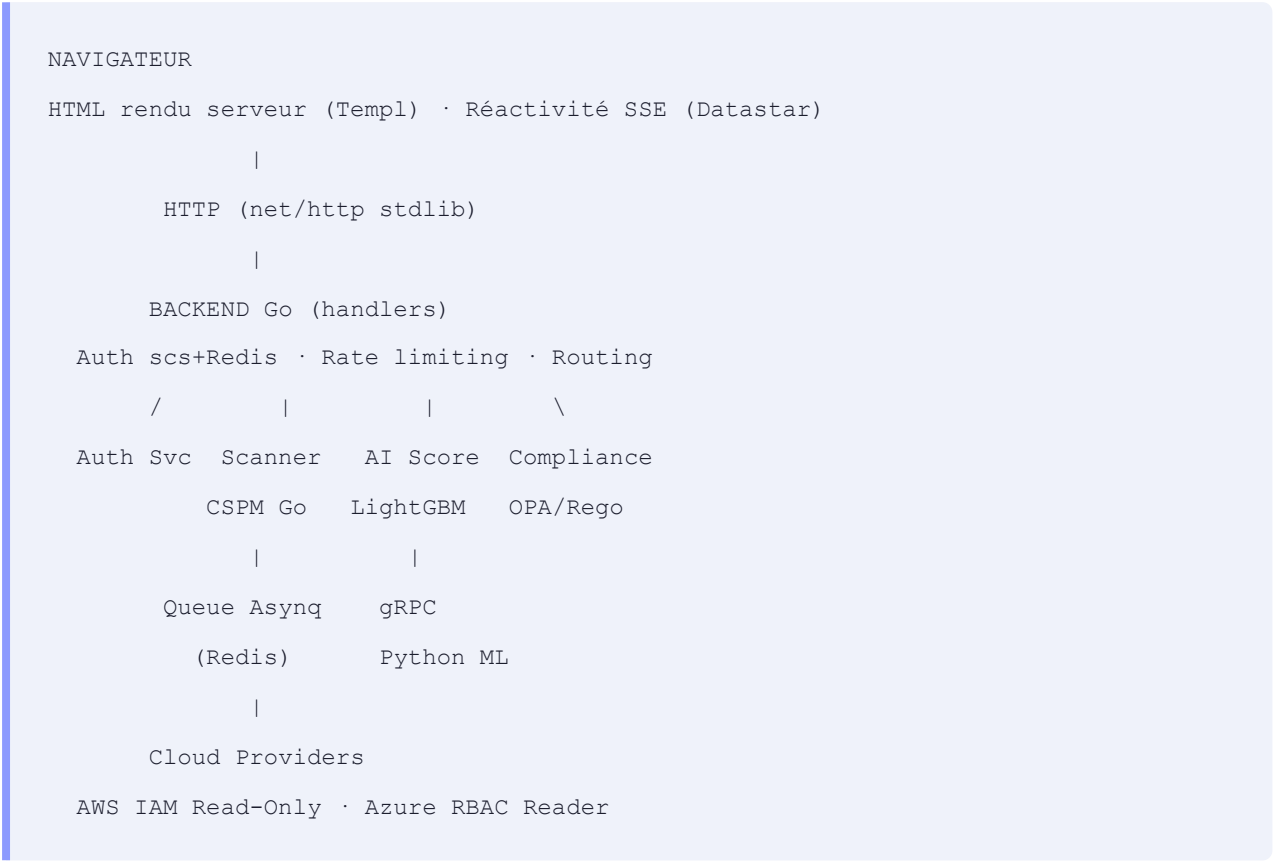
Principe	Implication
Simplicité d'onboarding	Connexion cloud en < 5 min, sans expertise DevOps requise
Sécurité by design	Remédiation avec approval humain obligatoire en v1
IA réaliste	LightGBM + données synthétiques, feedback loop opt-in dès phase 3
Standards ouverts	OPA/Rego pour compliance, moteur scanner open-source Apache 2.0
Multi-cloud progressif	AWS phase 1, Azure phase 2, GCP phase 3

1.3 Feuille de Route

- **Phase 1 (MVP)** : AWS · Scanner CSPM · Score IA · Coûts · Dashboard
 - **Phase 2 (V1)** : + Azure · Compliance OPA · Remédiation one-click · API publique
 - **Phase 3 (V2)** : + GCP · Feedback loop ML · Chatbot IA · SSO SAML · White-label
-

2. Architecture Générale

2.1 Vue d'ensemble



2.2 Stack Technique

Pour la justification détaillée de chaque choix technologique (alternatives évaluées, avantages/inconvénients), voir [Justification_Choix_CIRA.docx](#) , sections 1 et 2.

Composant	Technologie	Justification
Backend API	Go 1.26	Performance, typage fort, faible empreinte mémoire
Scanner CSPM	Go (open-source, Apache 2.0)	Contributeurs externes, crédibilité (cf. Trivy)
Frontend	Templ + TemplUI + Tailwind	Server-side rendering Go, zéro bundle JS

Temps réel	Datatar (SSE)	Streaming logs/métriques, < 15KB client
Base de données	PostgreSQL 18	ACID, JSON natif pour les findings
Sessions	alexedwards/scs + Redis	TTL natif, révocation immédiate au logout
Cache / Queue	Redis 8 + Asynq	Pub/Sub SSE, jobs scans asynchrones
ML Scoring	Python 3.12 + LightGBM	Rapidité d'inférence, faible RAM
ML Communication	gRPC (protobuf)	Contrat strict Go ↔ Python, < 5ms latence
Compliance	OPA 0.60 + Rego	Maintenabilité, policy packs CIS communautaires
CI/CD	GitHub Actions	Intégration native repository
Livraison	Docker + Docker Compose	Déploiement self-hosted client

3. Module 1 — Authentification et Gestion des Comptes

3.1 Description Fonctionnelle

L'utilisateur peut s'inscrire et se connecter via email/mot de passe ou OAuth (Google, Microsoft). La session est maintenue par cookie sécurisé (alexedwards/scs + Redis store). La gestion multi-utilisateurs (organisations) est prévue dès la v1.

3.2 Spécifications Techniques

Élément	Spécification
Sessions	alexedwards/scs + Redis store · TTL : 30 jours · Cookie HttpOnly + Secure + SameSite=Lax
OAuth providers	Google OAuth 2.0, Microsoft Entra ID
Hashage passwords	bcrypt (cost factor 12)
2FA	TOTP RFC 6238 — optionnel v1, obligatoire admin v2
Rate limiting login	5 tentatives / 15 min par IP

3.3 Critères d'Acceptance

- **AC-AUTH-01** : Inscription via email < 2 min, email de confirmation reçu en < 30 secondes.
- **AC-AUTH-02** : Connexion OAuth redirige vers le dashboard en < 3 secondes.
- **AC-AUTH-03** : Après 5 tentatives échouées, blocage 15 min + email d'alerte à l'utilisateur.

3.4 Dépendances

- Service SMTP (AWS SES ou Resend)
 - Google OAuth App configurée (console.cloud.google.com)
 - Microsoft Entra App configurée (portal.azure.com)
-

4. Module 2 — Connexion Cloud (AWS + Azure)

4.1 Description Fonctionnelle

AWS : CIRA génère un template CloudFormation créant un rôle IAM read-only. L'utilisateur déploie ce stack depuis sa console, copie le Role ARN et le colle dans CIRA. CIRA assume ce rôle via `sts:AssumeRole`.

Azure (phase 2) : CIRA guide l'utilisateur pour créer un Service Principal avec le rôle "Reader" sur son abonnement. L'utilisateur fournit `tenant_id`, `client_id`, `client_secret`.

4.2 Permissions AWS minimales requises

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "iam:Get*", "iam:List*",
      "s3:GetBucketAcl", "s3:GetBucketPolicy", "s3:ListAllMyBuckets",
      "ec2:Describe*", "rds:Describe*",
      "cloudtrail:GetTrailStatus", "cloudtrail:DescribeTrails",
      "lambda:ListFunctions", "lambda:GetPolicy",
      "ce:GetCostAndUsage"
    ],
    "Resource": "*"
  }]
}
```

4.3 Critères d'Acceptance

- **AC-CLOUD-01** : Processus de connexion AWS end-to-end < 5 minutes pour un utilisateur non-expert.
- **AC-CLOUD-02** : En cas de Role ARN invalide, message d'erreur explicite + lien documentation en < 3 secondes.
- **AC-CLOUD-03** : Credentials Azure chiffrés AES-256 au repos, jamais exposés dans logs ou réponses API.

4.4 Contraintes de Sécurité

- Credentials ne transitent jamais en clair (TLS 1.3 obligatoire)
 - Rotation automatique proposée tous les 90 jours
 - Révocation depuis CIRA = suppression immédiate des credentials stockés
-

5. Module 3 — Scanner CSPM (moteur Go, open-source)

5.1 Stratégie Open-Source

Pour la justification de la stratégie open-source et ses implications commerciales, voir [Justification_Choix_CIRA.docx](#) , section 6.1.

Le moteur Go de scan est publié en open-source (Apache 2.0) pour attirer des contributeurs et renforcer la crédibilité (modèle Trivy/Cloudsploit). Le scoring IA, la remédiation et le dashboard restent propriétaires.

5.2 Checks AWS — Phase 1 (10 règles critiques)

ID	Catégorie	Description	Sévérité
AWS-IAM-001	IAM	Utilisateur avec AdministratorAccess actif	Critical
AWS-IAM-002	IAM	Root account sans MFA	Critical
AWS-S3-001	Storage	Bucket S3 accessible publiquement	High
AWS-EC2-001	Network	Security Group ouvert 0.0.0.0/0 sur port 22 ou 3389	High
AWS-RDS-001	Database	Instance RDS accessible depuis Internet	High
AWS-RDS-002	Database	Instance RDS sans chiffrement at-rest	Medium
AWS-EBS-001	Storage	Volume EBS non chiffré	Medium
AWS-CT-001	Audit	CloudTrail désactivé	Medium
AWS-EC2-002	Secrets	Secret en clair dans user-data EC2	High

AWS-LAM-001	Compute	Lambda avec wildcard resource permissions	Medium
-------------	---------	---	--------

5.3 Checks Azure — Phase 2 (10 règles critiques)

ID	Catégorie	Description	Sévérité
AZ-IAM-001	IAM	Rôle Owner assigné à utilisateur externe	Critical
AZ-IAM-002	IAM	Compte admin sans MFA	Critical
AZ-BLOB-001	Storage	Blob Storage avec accès public activé	High
AZ-NSG-001	Network	NSG avec règle inbound Any:Any	High
AZ-SQL-001	Database	Azure SQL sans chiffrement TDE	Medium
AZ-SQL-002	Database	Azure SQL accessible depuis Internet	High
AZ-MON-001	Audit	Diagnostic logs désactivés	Medium
AZ-KV-001	Secrets	Key Vault sans soft-delete activé	Medium
AZ-VM-001	Compute	VM sans endpoint protection	Medium
AZ-NET-001	Network	VNet sans Network Watcher activé	Low

5.4 Spécifications Techniques

Élément	Spécification
Langage	Go 1.26
Parallélisme	Goroutines par type de ressource (max 10 concurrent)
Timeout total	5 min par compte cloud
Output	JSON structuré → PostgreSQL
Mode déclenchement	Pull planifié + Push webhook CloudTrail Events

5.5 Critères d'Acceptance

- **AC-SCAN-01** : Scan complet d'une infrastructure AWS < 100 ressources termine en < 5 minutes.
 - **AC-SCAN-02** : Taux de faux positifs sur les 10 règles critiques < 5% (mesuré sur dataset de test).
 - **AC-SCAN-03** : En cas d'erreur 403 sur une ressource, le scanner isole cette ressource et continue sans interruption globale.
-

6. Module 4 — Scoring IA (LightGBM)

6.1 Description Fonctionnelle

Un modèle LightGBM calcule un score de sécurité global (0–100) contextuel, prenant en compte l'exposition Internet, la probabilité de données sensibles, les combinaisons de risques et l'historique d'exploitation public (CVE).

6.2 Features principales du modèle

Feature	Description
<code>vuln_count_critical</code>	Nombre de vulnérabilités Critical
<code>internet_exposed_resources</code>	Ressources accessibles depuis <code>0.0.0.0/0</code>
<code>mfa_coverage_pct</code>	% de comptes IAM avec MFA activé
<code>encryption_at_rest_pct</code>	% de ressources chiffrées at-rest
<code>cloudtrail_enabled</code>	Boolean
<code>public_buckets_with_data_risk</code>	Buckets publics avec probabilité de données sensibles
<code>days_since_last_key_rotation</code>	Rotation des access keys IAM

6.3 Dataset et Stratégie d'Entraînement

Phases 1–2 (synthétique) : Modèle entraîné sur 10 000 infrastructures synthétiques calibrées sur les rapports AWS Security Hub publics.

Phase 3 (feedback loop opt-in) : Les clients peuvent rejoindre un programme anonymisé. Leurs résultats de scan (dépouillés de toute donnée d'identification) alimentent un réentraînement mensuel. C'est le vrai différenciateur compétitif de CIRA à long terme.

6.4 Critères d'Acceptance

- **AC-AI-01** : Score disponible en < 2 secondes après fin du scan.
- **AC-AI-02** : AUC-ROC ≥ 0.85 pour la classification "infrastructure à risque élevé" sur le dataset de test.

- **AC-AI-03** : Rapport de performance du modèle produit à chaque phase (v1, v2) avec comparaison vs baseline.
-

7. Module 5 — Analyse des Coûts

7.1 Détections Phase 1 (AWS)

Type	Critère	Économie calculée
EC2 surdimensionné	CPU moyen < 10% sur 7 jours consécutifs	Différentiel entre instance actuelle et recommandée
EBS non attaché	Volume sans attachement depuis > 7 jours	Coût mensuel du volume
Snapshot ancien	Snapshot > 90 jours sans usage récent	Coût stockage S3 Glacier
Elastic IP libre	EIP non attachée à une instance running	3,65 €/mois (tarif AWS)
RDS arrêtée longtemps	État "stopped" > 7 jours	Coût stockage provisionné

7.2 Spécifications Techniques

- Source prix : AWS Pricing API (mise à jour quotidienne, cache Redis 24h)
- Devise : EUR (conversion taux BCE du jour)
- Prédiction J+7 : régression linéaire pondérée sur 30 derniers jours
- Alerte pic : déclenchée si dépense $> \mu + 1.5\sigma$ (rolling 7 jours)

7.3 Critères d'Acceptance

- **AC-COST-01** : Économies calculées avec prix AWS du jour ($\pm 5\%$ tolérance sur conversion de devise).
- **AC-COST-02** : Alerte de pic de coût envoyée en < 15 minutes après détection d'une anomalie > 30% vs moyenne.
- **AC-COST-03** : Graphique 90 jours de données charge en < 2 secondes.

8. Module 6 — Compliance as Code (OPA/Rego)

8.1 Standards Couverts

Framework	Phase 2	Phase 3
CIS AWS Foundations	15 règles essentielles	+ 35 règles (total 50)
CIS Azure Foundations	—	20 règles
RGPD	5 règles (chiffrement, logs, rétention)	+ 3 règles
NIS2	5 règles (backups, MFA, gestion incidents)	+ 5 règles

8.2 Exemple de Politique Rego

```
package cira.aws.cis.cloudtrail

deny[msg] {
    trail := input.cloudtrail_trails[_]
    not trail.is_logging
    msg := sprintf("CloudTrail '%v' is not logging", [trail.name])
}

deny[msg] {
    count(input.cloudtrail_trails) == 0
    msg := "No CloudTrail trail configured in this account"
}
```

8.3 Critères d'Acceptance

- **AC-COMP-01** : Évaluation des 25 règles de compliance (phase 2) en < 500ms par compte.
- **AC-COMP-02** : Rapport PDF de conformité généré et téléchargeable en < 10 secondes.
- **AC-COMP-03** : Ajout d'une nouvelle règle Rego sans redéploiement applicatif (hot-reload OPA bundle).

9. Module 7 — Remédiation “One-Click Safe”

9.1 Principe Fondamental (V1)

CIRA génère du code Terraform pour corriger une vulnérabilité, exécute un `terraform plan` (dry-run), et présente le plan à l'utilisateur. Aucune modification n'est appliquée en production sans validation humaine explicite.

Ce choix est une décision de risk management délibérée : appliquer du Terraform en prod depuis une plateforme tierce sans supervision = risque de downtime client + responsabilité légale. La v2 pourra proposer l'auto-remédiation une fois que CIRA aura des centaines de clients stables et des preuves de fiabilité.

9.2 Workflow Complet

1. Vulnérabilité détectée
↓
2. CIRA génère le code Terraform correctif
↓
3. CIRA exécute `terraform plan` (dry-run, 0 modification)
↓
4. Utilisateur consulte le plan (résumé humanisé + raw Terraform)
↓
5. Utilisateur clique "Approuver et appliquer" (double confirmation)
↓
6. CIRA exécute `terraform apply` (state isolé par compte client)
↓
7. Si erreur → rollback automatique (`terraform destroy` du changement)
↓
8. Rescan automatique 24h après pour vérification

9.3 Périmètre de Remédiation V1

Vulnérabilité	Action Terraform générée
Bucket S3 public	<code>aws_s3_bucket_public_access_block</code>

Security Group trop ouvert	Suppression règle inbound <code>0.0.0.0/0</code>
RDS sans chiffrement	Snapshot + restauration <code>storage_encrypted = true</code>
EBS non chiffré	Snapshot + nouveau volume chiffré
CloudTrail désactivé	Création trail + S3 bucket dédié

9.4 Critères d'Acceptance

- **AC-REM-01** : Code Terraform généré passe `terraform validate` sans erreur dans 100% des cas (5 types v1).
 - **AC-REM-02** : En cas d'échec de `terraform apply`, rollback automatique en < 60 secondes.
 - **AC-REM-03** : Minimum 2 actions distinctes requises avant toute exécution en production (clic + confirmation modale).
 - **AC-REM-04** : Le plan Terraform est présenté en langage humanisé en plus du raw output.
-

10. Module 8 — Dashboard et Reporting

10.1 Métriques Affichées

Métrique	Calcul	Affichage
Security Score	Score LightGBM normalisé 0–100	Jauge + tendance ↑↓
Cost Optimization Score	% économies possibles / dépenses totales	Jauge + montant €/mois
Compliance Score	Règles conformes / règles totales	Fraction + %
Top 5 Vulnérabilités	Triées par sévérité + exposition	Liste cliquable
Top 5 Économies	Triées par montant € potentiel	Liste cliquable

10.2 Rapport PDF Exportable

- Résumé exécutif 1 page (lisible par DSI non-technique)
- Scores avec contexte et tendance temporelle
- Liste complète findings avec sévérité et recommandation
- Détail compliance par framework
- Charte graphique CIRA (Barlow, #5368FE , #EFF2FA)

10.3 Critères d'Acceptance

- **AC-DASH-01** : Dashboard TTI < 1.5 secondes sur connexion 10 Mbps.
- **AC-DASH-02** : Rafraîchissement temps réel pendant scan (latence SSE Datastar < 500ms).
- **AC-DASH-03** : Rapport PDF correct sur Chrome, Firefox, Safari, Edge, mobile Chrome.

11. Module 9 — Alertes et Notifications

11.1 Types d'Alertes

Événement	Canal	Délai max	Configurable
Scan terminé	Email	2 min	Oui
Nouvelle vulnérabilité Critical	Email	5 min	Oui
Pic de coût > 30%	Email	15 min	Seuil configurable
Rapport hebdomadaire	Email	Lundi 8h	Oui
Notifications Slack	Slack	5 min	Phase 2

11.2 Critères d'Acceptance

- **AC-ALERT-01** : Notification email pour vulnérabilité critique reçue en < 5 minutes.
 - **AC-ALERT-02** : Templates email HTML responsive lisibles sur mobile.
 - **AC-ALERT-03** : Désabonnement à un type d'alerte effectif immédiatement, sans reconnexion.
-

12. Module 10 — Routes HTTP (Phase 2)

12.1 Routes

Méthode	Route	Description
GET	<code>/accounts</code>	Liste des comptes cloud connectés
POST	<code>/accounts</code>	Ajouter un compte cloud
POST	<code>/scans</code>	Déclencher un scan manuel
GET	<code>/scans/{id}</code>	Statut et résultats d'un scan
GET	<code>/scans/{id}/stream</code>	Stream SSE logs scan temps réel
GET	<code>/findings</code>	Liste des findings (filtrable par sévérité, cloud)
GET	<code>/scores</code>	Scores actuels
GET	<code>/costs/stream</code>	Stream SSE métriques coûts
GET	<code>/reports/{id}</code>	Télécharger un rapport PDF

12.2 Critères d'Acceptance

- **AC-Router-01** : Réponses JSON avec champ `request_id` pour traçabilité.
 - **AC-Router-02** : Rate limiting à 100 req/min par session, header `X-RateLimit-Remaining` dans chaque réponse.
-

13. Contraintes Non-Fonctionnelles

Catégorie	Contrainte	Seuil
Performance	Temps de réponse Web (p95)	< 200 ms
Performance	Durée scan AWS standard (< 100 ressources)	< 5 min
Performance	Génération rapport PDF	< 10 s
Disponibilité	Uptime SLA mensuel	≥ 99.5%
Sécurité	Chiffrement données au repos	AES-256
Sécurité	Transport	TLS 1.3 minimum
Scalabilité	Utilisateurs simultanés par instance	100 phase 1 → 1 000 phase 2
RGPD	Hébergement	Responsabilité du client (self-hosted)
Audit	Rétention logs d'actions	12 mois minimum

14. Questions Ouvertes / Décisions à Prendre

#	Question	Impact	Deadline
QO01	Fournisseur email : AWS SES vs Resend ?	Coût, délivrabilité	Phase 1
QO02	Seuil alerte coût paramétrable dès v1 ou fixé à 30% ?	Feature scope	Phase 1
QO03	Isolation Terraform state : par client ou par compte cloud ?	Sécurité + coût	Phase 2
QO04	Programme feedback ML : DPA RGPD à rédiger avec un juriste	Légal	Phase 3

15. Historique des Versions

Version	Date	Auteur	Résumé des changements
v1.0	2025-07-10	Équipe CIRA	Création initiale — 10 modules, stack technique, critères d'acceptance. Statut : Draft.
v4.0	2026-05-06	Équipe CIRA	Abandon GraphQL → HTTP natif. Abandon React + Apollo → Templ + Datastar. Abandon JWT → sessions cookie scs + Redis. Ajout routes SSE. Suppression contrainte hébergement EU (self-hosted client). Mise à jour SP (202 SP, 808h, 20 semaines).

CIRA — Cloud Infrastructure Realtime Analysis | Document projet interne